INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Course 1: GRC101 - Introduction to Governance, Risk, and Compliance

Week 3 Lab Assignment: Risk Management Fundamentals

Student Name: Ovat Cyril Gift
Date: 30/01/2026
Instructor:

Lab Objectives:

This lab assignment is designed to help you:

- Understand the fundamental concepts of risk management in cybersecurity
- Apply risk identification, assessment, and mitigation methodologies
- Develop skills in creating risk matrices and prioritizing risks
- Gain practical experience in developing risk treatment plans

Instructions:

Complete all parts of this lab assignment. Submit your completed document to your instructor by the due date. All answers should be typed directly into this document.

Part 1: Risk Management Concepts (20 points)

1. Define the following terms in your own words and explain their relationship to each other: risk, threat, vulnerability, impact, and likelihood. (10 points)

Answer:

1. **Risk**: A potential loss that a threat can exploit in an organization process or system.
2. **Threat**: An event, circumstance and or a physical agent that exploit the weakness of a process, system and or technology in an organization to cause a potential loss.
3. **Vulnerability:** The weakness that exist in an organization's system, process or technology with the capacity to cause a potential loss to that organization.
4. **Impact**: The actual loss an organization incur after a threat exploits the vulnerability of an organization's process, system and or technology.
5. **Likelihood**: The probability that an event will occur.

2. Compare and contrast qualitative and quantitative risk assessment methodologies. What are the advantages and disadvantages of each approach? When would you recommend using one over the other? (10 points)

Answer:

Comparison between qualitative and quantitative Risk assessment methodologies	
Qualitative Risk assessment	**Quantitative Risk Assessment**
Risk assessment is based on the assessor's descriptive judgment (High, medium and low).	Risk assessment is calculated using numerical data to arrive at the likelihood and impact instead of just descriptive judgment.
Advantages of qualitative and quantitative Risk assessment methodologies	
Qualitative Risk assessment	**Quantitative Risk Assessment**
It is easy to Understand and communicate.	It provides a detailed and objective analysis of risks.
It is simple to implement.	The result of risks analysis can be quantifiable.
It is biased since it is based on assessor's subjective judgment.	Provides reliability of judgement since calculation is based on data and statistical tools other than subjective judgment.
Disadvantages of qualitative and quantitative Risk assessment methodologies	
Qualitative Risk assessment	**Quantitative Risk Assessment**
It can over-simplify complex risks.	The calculation can be complicated to non-technical experts.
Risks cannot be quantifiable since it is subjective.	It needs reliable data and such may not be always available for computation.

Qualitative risk assessment is suitable for initial evaluations and or when quick assessments are needed, while quantitative assessments are suitable for detailed analysis when reliable data are available for calculations.

Part 2: Risk Identification Exercise (25 points)

For this exercise, consider a medium-sized financial services company that is planning to migrate its customer relationship management (CRM) system from an on-premises solution to a cloud-based service. The CRM system contains sensitive customer financial information and personally identifiable information (PII).

Identify at least 10 potential risks associated with this migration. For each risk, provide:
1. A clear risk statement
2. The risk category (e.g., technical, operational, compliance, reputational)
3. The potential threat source or actor
4. The vulnerability being exploited

Risk Statement	Risk Category	Threat Source/Actor	Vulnerability
Data Loss due to incomplete migration.	Operational	Human Error.	Lack of documented process for data migration.
Unauthorized access to customer data in the cloud platform.	Technical	Employee and or black hat hackers.	Lack of a strong access control.
Non-compliance to data protection regulations like GDPR.	Compliance	Employees.	No implementation or poor implementation of regulations.
The malicious use of customer data by employees with access to sensitive customer data.	Operational	Mischievous employees.	Lack of reviewing (monitor) the activities of employees with access to sensitive data.
Unavailability of customer relationship management system due to service outage.	Operational	Cloud service interruptions.	Poor cloud services.
Inadequate data encryption leading to the exposure of customer data.	Technical	Hackers.	Poor customer data encryption.
Phishing attacks during migration process.	Operational	Black hat hackers.	Poor security awareness among employees.
Access to customer data without proper authentication.	Technical	Black hat hackers.	Lack of multiple factor authentication.
Difficulty in systems integration with cloud platform.	Operational	IT Team.	Lack of system compatibility.
Inadequate testing of the new cloud system could lead to functionality issues after migration.	Operational	IT Team.	Lack of thorough testing of the cloud systems before migration.

Part 3: Risk Assessment Matrix (25 points)

From the risks you identified in Part 2, select the five most significant risks and complete the following risk assessment matrix. For each risk:

1. Assign a likelihood rating (1-5, where 1 is rare and 5 is almost certain)
2. Assign an impact rating (1-5, where 1 is negligible and 5 is severe)
3. Calculate the risk score (likelihood × impact)

4. Determine the risk level based on the score:
   - Low: 1-4
   - Medium: 5-9
   - High: 10-15
   - Critical: 16-25

Risk	Likelihood (1-5)	Impact (1-5)	Risk Score	Risk Level
Unauthorized access to customer data in the cloud platform.	**4**	**5**	**20**	**Critical**
Inadequate data encryption leading to the exposure of customer data.	**4**	**5**	**20**	**Critical**
Non-compliance to data protection regulations like GDPR	**4**	**5**	**20**	**Critical**
Unavailability of customer relationship management system due to service outage	**3**	**4**	**12**	**High**
The malicious use of customer data by employees with access to sensitive customer data.	**3**	**4**	**12**	**High**

Part 4: Risk Mitigation Strategies (30 points)

For the three highest-rated risks from your assessment in Part 3, develop detailed risk mitigation strategies. For each risk:

1. Describe the risk mitigation approach (avoid, transfer, mitigate, or accept)
2. Provide specific controls or actions to implement
3. Identify the responsible stakeholders
4. Establish metrics to measure the effectiveness of the mitigation
5. Estimate the residual risk after mitigation (low, medium, or high)

Risk 1:

Risk Statement	Unauthorized access to customer data in the cloud platform.
Mitigation Approach	Mitigate.
Specific Controls/Actions	Implement multi-factor authentication.
Responsible Stakeholders	IT officers and compliance officers.
Effectiveness Metrics	Zero rate of unauthorized access.
Residual Risk	Low.

Risk 2:

Risk Statement	Inadequate data encryption leading to the exposure of customer data.
Mitigation Approach	Mitigate
Specific Controls/Actions	Data should be encrypted at all times (At rest and in transit).
Responsible Stakeholders	IT team and data protection officers.
Effectiveness Metrics	Presence of encrypted data at rest and in transit.
Residual Risk	Low.

Risk 3:

Risk Statement	Non-compliance to data protection regulations like GDPR.
Mitigation Approach	Mitigate.
Specific Controls/Actions	Conduct a wholistic compliance review.
Responsible Stakeholders	Compliance officers.
Effectiveness Metrics	Audit reports on compliance requirements.
Residual Risk	Low.

Submission Guidelines:

1. Save this document with the filename format:
GRC101_Week3_Lab_FirstName_LastName.docx
2. Submit your completed lab assignment through the course learning management system.
3. Due date: [Instructor to specify]

Grading Rubric:

- **Part 1: Risk Management Concepts - 20 points**
- **Part 2: Risk Identification Exercise - 25 points**
- **Part 3: Risk Assessment Matrix - 25 points**

- **Part 4: Risk Mitigation Strategies - 30 points**

Total: 100 points